

Endpoint Detection and Response (EDR)

Notes by Imon · September 2026 · github.com/imon333/SOC_Level_1

Task 1 – Introduction

EDR is one of the tools a SOC analyst works with every day, so this room is about understanding what it actually does on an endpoint: how it is different from a normal antivirus, what data it collects, and how an analyst uses it to detect and respond to threats. The room ends with triaging a few alerts in a simulated EDR console.

What I wanted to get out of this room:

- The basics of EDR and how it works
- How EDR differs from a traditional antivirus
- The architecture of an EDR solution (agents and console)
- What kind of telemetry it collects from endpoints
- Its detection and response capabilities
- Investigating a realistic alert in an EDR

Prerequisites mentioned: basic knowledge of endpoints (Windows, Linux, Mac), the common attacks against them, and the role of a SOC team.

Task 2 – What is EDR?

Most company security is built around the network: firewalls and other perimeter controls. The problem is that with remote work, laptops are often outside that perimeter, so they lose that protection. EDR solves this by protecting the endpoint itself, wherever it is. The agent on the device keeps monitoring it all the time, whether the device is in the office or at home.

Some EDR products on the market: CrowdStrike Falcon, Symantec EDR, SentinelOne and Microsoft Defender for Endpoint. The architecture is mostly the same across vendors, only the features differ. The room used CrowdStrike Falcon screenshots as the example.

The three pillars of EDR

1. Visibility. This is what makes EDR stand out. It collects detailed data from the endpoint: process changes, registry changes, file and folder changes, user actions and more. The analyst sees the full process tree with a timeline of what happened in which order, and can also go back to historical data for threat hunting. Every detection arrives with its full context. In CrowdStrike's process tree view, every node is a process and the lines show parent-child relationships; expanding a node shows the network connections, registry changes and file changes of that process.

2. Detection. EDR uses both signature-based and behaviour-based detection. With machine learning it learns the normal baseline and flags deviations, it can catch fileless malware that only lives in memory, and we can feed it our own IOCs. The detections page lists every alert with severity, time, triggering file, hostname, user, and the MITRE tactic/technique it maps to.

3. Response. The analyst can act directly from the central console: isolate a host, kill a process, quarantine a file, or connect remotely to the machine (CrowdStrike calls this RTR, Real Time Response).

Task 6 covers this in more detail.

Important limitation: EDR is a host-only solution. It does not detect network-level threats.

Room questions

Which feature of EDR provides a complete context for all the detections?

Visibility

Task 3 – Beyond Antivirus

My first question was: if we already have antivirus, why do we need EDR? Both protect the endpoint, but the depth of protection is very different. The room explains it with an airport analogy that made it click for me:

Airport	Endpoint security	What it does
Immigration check	Antivirus (AV)	Checks each passport against a list of known criminals. Blocks a match, but lets in anyone who has no record, even a trained thief.
Security officers inside	EDR	Watch CCTV and motion sensors all the time. Notice if someone walks near restricted areas, behaves strangely or leaves a bag. Can act or alert management with full details.

So AV mostly relies on known signatures, while EDR monitors and records behaviour. EDR also works organisation-wide: if a suspicious file is found on one endpoint, it checks for it on all the others.

Walking through an attack step by step

The room compared how AV and EDR react to the same attack chain:

- User receives a phishing email with a Word document containing a malicious VBA macro
- User downloads and opens the document
- The macro runs silently and spawns PowerShell
- An obfuscated PowerShell command downloads a second-stage payload
- The payload is injected into a legitimate svchost.exe
- The attacker gets remote access to the system

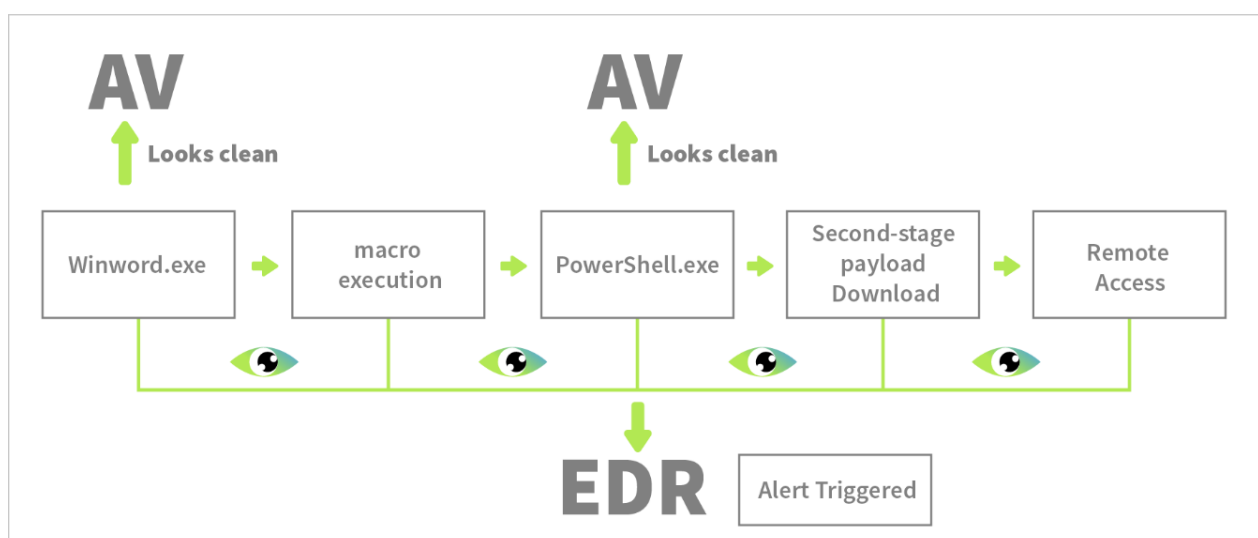


Figure 1: AV looks at single events and sees nothing wrong; EDR watches the whole chain and raises an alert.

Step	Antivirus	EDR
1. Download	Nothing, if the file has no known signature	Logs the download and keeps watching it
2. Open doc	Nothing, winword.exe is legitimate	Records winword.exe execution
3. Macro runs	Nothing, if no signature exists	Flags the unusual parent-child relation winword.exe → powershell.exe
4. PowerShell	Usually misses obfuscated scripts	Flags obfuscated script execution
5. Injection	Doesn't monitor memory injection	Detects process injection into svchost.exe
6. Remote access	No network-level visibility	Flags svchost.exe making an unexpected outbound connection
Result	Likely marked as clean	One alert with the full attack chain, analyst can respond from the console

Note from the room: some modern AVs have better visibility than this, but EDR is still a level above in both detection and response.

Room questions

In the given analogy, what represents an AV?

Immigration check

Task 4 – How Does EDR Work?

EDR has two main parts: agents on the endpoints and a central console.

Agents (sensors)

An agent is installed on every endpoint we want to protect. They are the eyes and ears of the EDR. They monitor all activity on the device and send it to the console in real time. Agents can also run some basic signature and behaviour detections locally and forward them to the console as alerts.

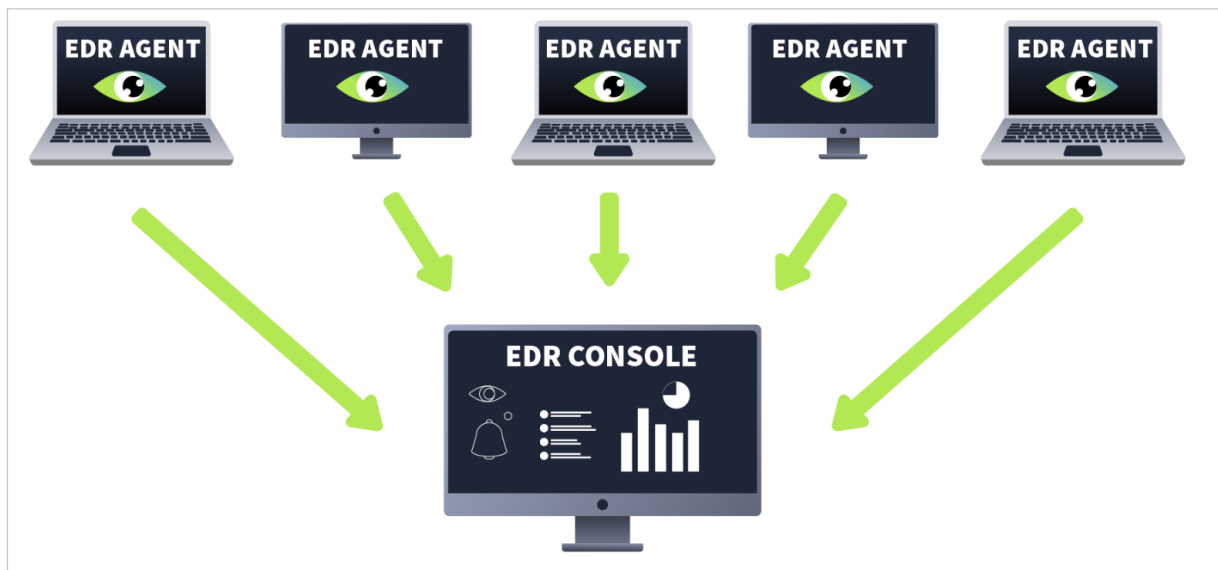


Figure 2: Many agents feed their data into one central EDR console.

EDR console

The console is the brain. It correlates all the data coming from the agents using detection logic, machine learning and threat intelligence, and connects the dots into a detection (alert). The dashboard gives an overview of detections across all endpoints.

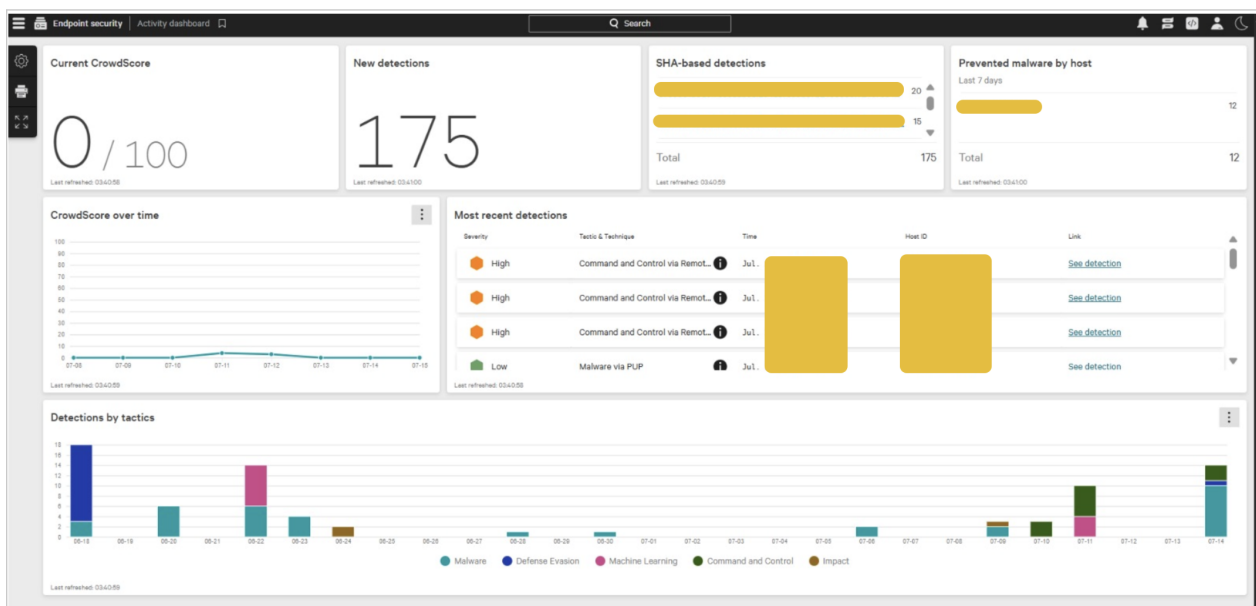


Figure 3: CrowdStrike Falcon dashboard with recent detections and detections by tactic.

What happens after a detection?

The analyst acknowledges the alert and prioritises it. EDR helps here by assigning a severity: **Critical, High, Medium, Low, Informational**. The highest severity gets investigated first. Opening the alert shows everything related to it: executed files and processes, network connection attempts, registry changes and so on. The analyst's first job is to decide: **true positive or false positive?** If it is a true positive, response actions can be taken from the console.

EDR in the bigger picture

EDR is not used alone. A network also has firewalls, DLP, email security gateways, IAM and other tools. All of them are usually integrated into a **SIEM**, which becomes the central place for investigations. SIEM comes later in the module.

Task 5 – EDR Telemetry

Telemetry is the data the agents collect and send to the console. I think of it as the black box of the endpoint: everything needed for detection and investigation is in there. Most activity on an endpoint is legitimate, so the more data we have, the easier it is to tell normal from malicious.

Telemetry	Why it matters
Process executions and terminations	Shows suspicious parent-child relationships, suspicious executables starting processes, malware payloads
Network connections	Reveals C2 connections, unusual ports, data exfiltration, lateral movement
Command line activity	Captures CMD and PowerShell commands, including obfuscated scripts that AV often misses
File and folder modifications	Catches data staging, ransomware activity and dropped malicious files
Registry modifications	The registry holds Windows configuration; attackers change it a lot (e.g. persistence)

The key point for me: advanced attackers use legitimate tools so each single action looks harmless. Only when you look at the whole telemetry together does the real story appear. That is what lets EDR catch them, and it also lets the analyst see the full chain of events, find the root cause and rebuild the attack timeline.

Task 6 – Detection and Response Capabilities

Detection techniques

Technique	How it works	Example
Behavioural detection	Looks at what a file or process does, not just its signature	winword.exe spawning powershell.exe
Anomaly detection	Learns the endpoint's normal baseline and flags deviations (can cause false positives, but context helps)	A process changes an auto-start registry key on a host where that never happens
IOC matching	Matches activity against threat intel feeds (works for everything except zero-days)	Hash of a dropped executable matches a known attack tool
MITRE ATT&CK mapping	Maps each flagged activity to a tactic and technique	Scheduled task creation → Persistence / Scheduled Task/Job
Machine learning	Models trained on normal and malicious behaviour detect complex patterns	A chain of harmless-looking steps (fileless or multi-stage attacks)

Response actions

Responses can be automatic (policies that block known bad behaviour) or manual. The manual options:

- **Isolate host** – cut the endpoint off from the network. Very effective for containment, since most attacks start on one machine and then move laterally.
- **Terminate process** – for machines that run core business services, isolation can cost more than the attack itself, so killing only the malicious process is better. Needs care: killing a legitimate process can break the system.
- **Quarantine** – moves a malicious file to an isolated location where it cannot run. Later the analyst restores or deletes it.
- **Remote access** – open a shell on the endpoint (e.g. CrowdStrike RTR) when the built-in actions are not enough. Useful for running scripts, custom actions or collecting data.

- **Artefact collection** – pull forensic data without physical access to the device: memory dump, event logs, specific folder contents, registry hives.

Task 7 – Practical: Triaging Alerts in the EDR

Scenario: I am a SOC analyst at TECH THM with access to an EDR console showing several medium and high severity detections. The task is to triage each one using only the information in the EDR (acknowledging and taking actions was out of scope).

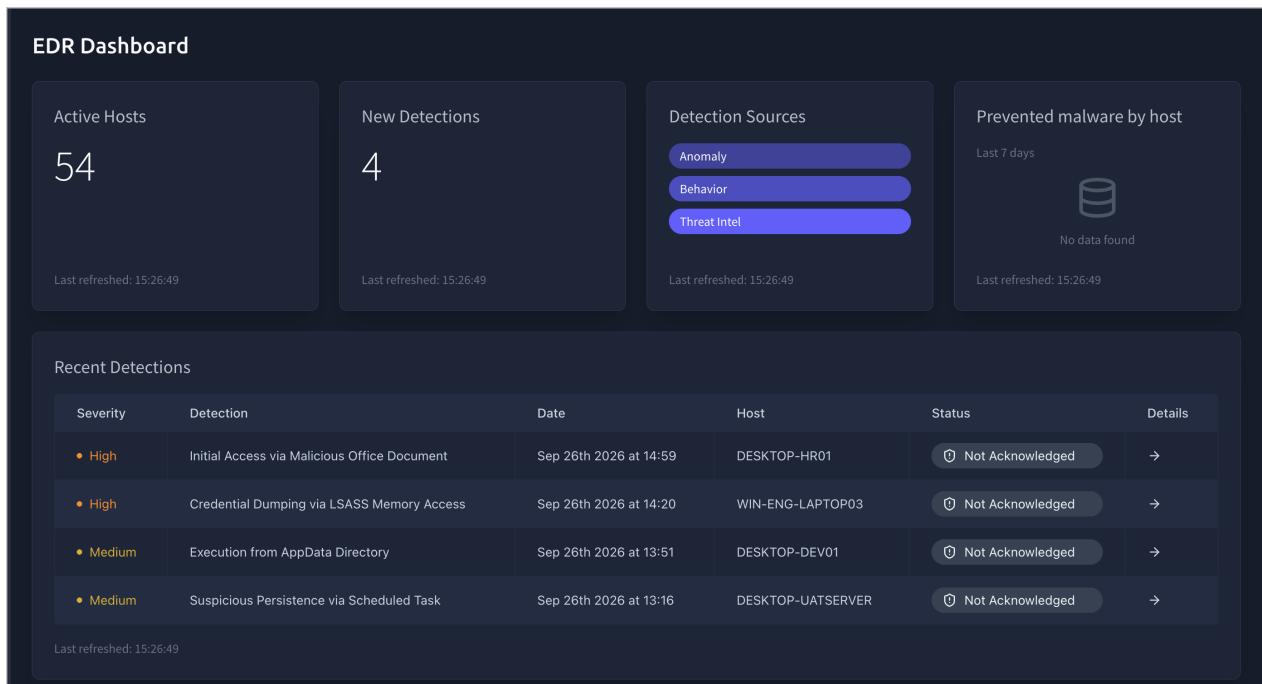


Figure 4: The lab dashboard with four unacknowledged detections on different hosts.

Detection 1: Initial Access via Malicious Office Document (DESKTOP-HR01)

The summary already tells most of the story. User `alice.thomas` opened a macro-enabled document `invoice.docm` in `WINWORD.EXE`. The macro launched `CMD`, which used `cURL` to download a payload from an external domain. The file was saved to disk but never executed, which looks like malware staging. MITRE mapping: Initial Access, T1566.001 Spearphishing Attachment.

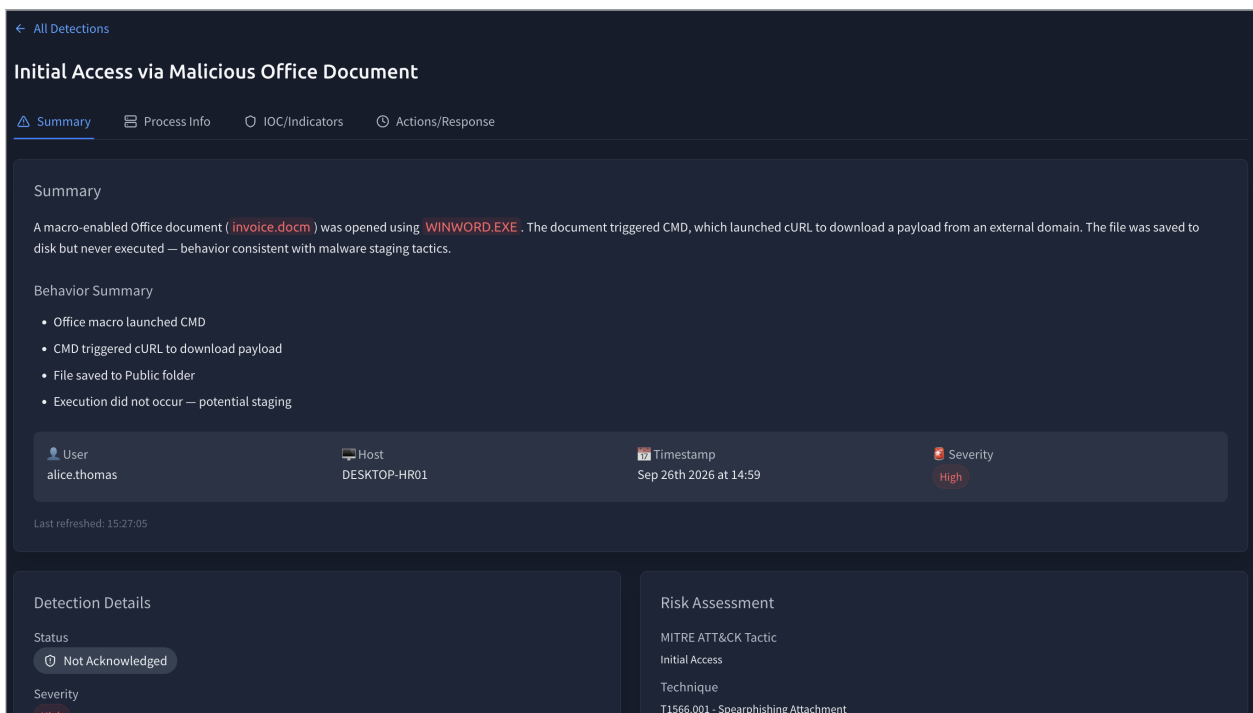


Figure 5: Detection summary with behaviour, user, host and MITRE mapping.

The Process Info tab shows the full chain:

WINWORD.EXE → CMD.EXE → cURL.EXE → INSTALL.EXE

WINWORD.EXE itself is a clean, Microsoft-signed binary started by explorer.exe. What makes it suspicious is the behaviour: it spawned CMD right after opening a macro-enabled document. This is exactly the parent-child relationship example from Task 6.

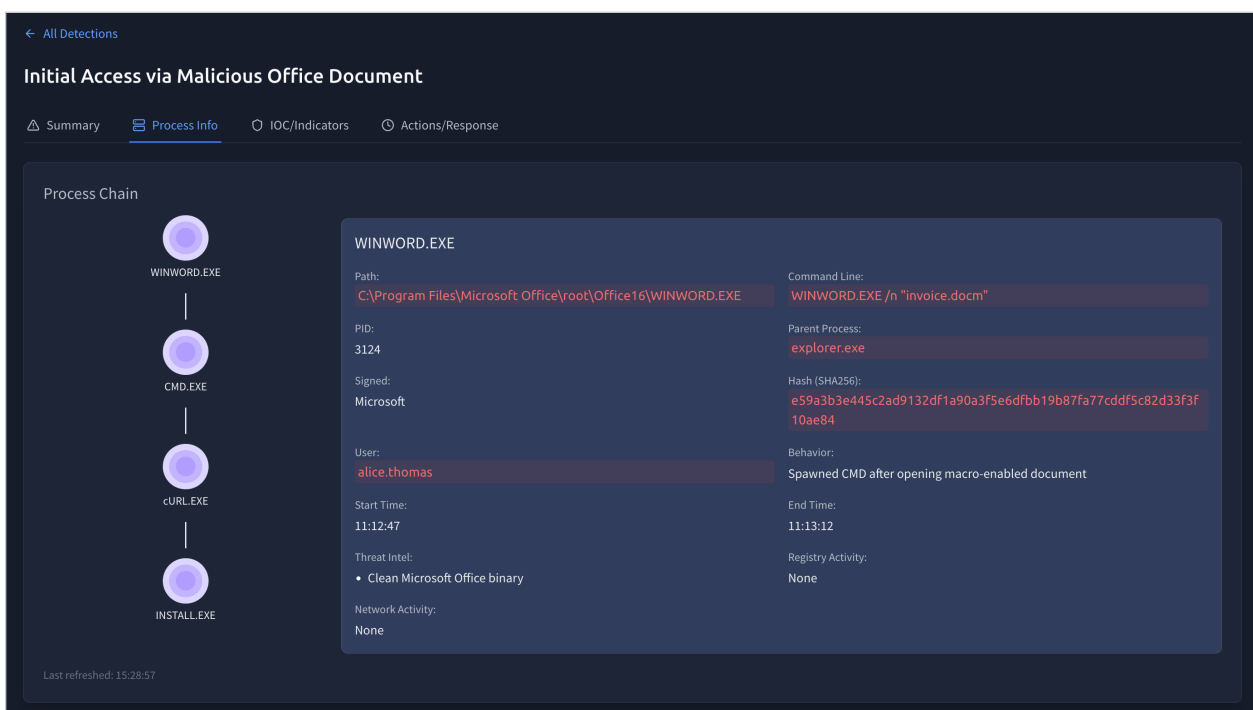


Figure 6: Process chain and details of WINWORD.EXE (signed, clean binary, suspicious behaviour).

The last node, INSTALL.EXE, is the actual payload: unsigned, dropped in C:\Users\Public\, known in malware campaigns according to threat intel, and already quarantined by the EDR before it could run.

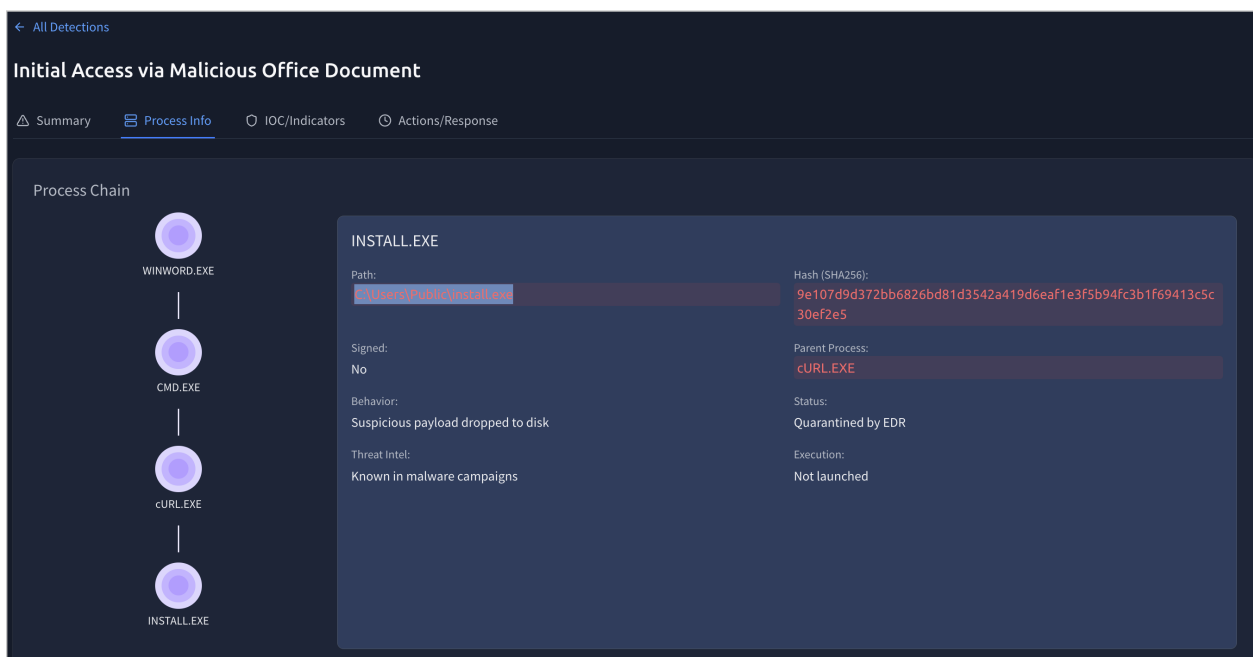


Figure 7: INSTALL.EXE, the downloaded payload, quarantined and not launched.

Room questions

Which tool was launched by CMD.exe to download the payload on DESKTOP-HR01?

cURL

What is the absolute path to the downloaded malware on DESKTOP-HR01?

C:\Users\Public\install.exe

Summary

After this room I understand why EDR is a core SOC tool: agents collect detailed telemetry from every endpoint, the console correlates it into alerts with full context, and the analyst can respond directly from one place. The biggest takeaway for me is that attackers hide behind legitimate processes, so looking at single events is not enough. The process chain and behaviour are what give it away. Next rooms in the module cover other SOC tools, including SIEM.